

A Vision for Compliance-Aware Requirements Engineering in the Age of the EU AI Act

 T.Y. Emmy Lai

Fraunhofer IAIS, Sankt Augustin, Germany
emmy.lai@iais.fraunhofer.de

Abstract—Validating AI system requirements against legal obligations is a growing challenge, particularly with the EU AI Act now in force and key compliance deadlines approaching from mid-2026. Current Requirements Engineering practice offers no systematic tooling: practitioner insights suggest that compliance validation remains largely manual, checklist-driven, and difficult to scale [1]. We present *Compliance-Aware Requirements Engineering System (CARES)*, a vision for a hybrid agent-based system that automates legal compliance and quality requirements validation in RE. CARES formalizes regulatory text into structured, testable requirements and validates project-level requirements using a 4CT quality schema: four core dimensions (Completeness, Consistency, Correctness, Coherence) grounded in IEEE/ISO/IEC 29148:2018, a promoted Traceability dimension reflecting legal auditability demands, and SMART criteria serving both as validation sub-criteria and as a remediation guide at the individual requirement level. Using the EU AI Act as the first application domain, we propose a hierarchical mapping architecture, a traffic-light Human-In-The-Loop (HITL) mechanism with formally defined trigger criteria, and a phased evaluation roadmap to guide future validation.

Index Terms—EU AI Act, Requirements Validation, Legal Compliance, Agent-Based Systems, Large Language Models

I. INTRODUCTION

The EU AI Act [2] entered into force in August 2024, with key obligations for high-risk AI systems taking effect from mid-2026 [3]. For development teams, this creates a concrete challenge: ensuring that AI project requirements satisfy legal obligations in a traceable, auditable, and scalable way. A practitioner study suggests that RE and compliance professionals overwhelmingly consider the Act relevant, yet none report using dedicated validation tooling, anticipating substantial increases in compliance effort [1].

Legal regulations are expressed in natural language, making NLP-based processing well-suited to their automated analysis. Their hierarchical organization into numbered articles and provisions further supports systematic decomposition into machine-processable, testable requirements [4]. However, legal language is inherently ambiguous: context-sensitive provisions such as “adequate risk management” (Art. 9 [2]) resist direct operationalization and require expert judgment, making full automation insufficient. This motivates a *structured* process for reproducible interpretation, an *explainable* one to keep compliance decisions auditable, and a *Human-In-The-Loop (HITL)* one to involve expert judgment wherever automated reasoning cannot reliably resolve ambiguity.

A. Problem Statement

The EU AI Act imposes concrete obligations on high-risk AI system providers across risk management (Art. 9), data governance (Art. 10), technical documentation (Art. 11), transparency (Art. 13), and human oversight (Art. 14) [2]. Three interconnected challenges explain the current tooling gap: (C1) **legal text ambiguity** in context-sensitive provisions, (C2) **a legal-technical language gap**, with no established methodology to translate obligations into testable requirements [4], and (C3) **a lack of ground truth**, as no annotated compliance dataset yet exists for the EU AI Act, making evaluation of automated tools significantly harder.

We present CARES (*Compliance-Aware Requirements Engineering System*), a hybrid system combining Foundation-Model (FM)-based agents with HITL oversight for automated legal compliance validation in RE. CARES comprises three architectural components: (i) a three-tier hierarchical mapping architecture linking legal obligations to project requirements; (ii) a **4CT quality schema** grounded in IEEE 29148:2018 [5] and refined by SMART criteria [6], [7]; and (iii) a traffic-light HITL mechanism with formally defined trigger criteria. Additionally, this paper contributes (iv) a phased evaluation roadmap directly targeting C3.

II. RELATED WORK

RE for Legal Compliance. A substantial body of prior work addresses legal requirements extraction using NLP [8], [9]; CARES builds on these foundations by extending automated extraction to full compliance validation against project-level requirements. Kelly et al. [10] interpret EU AI Act obligations via product quality models; Wagner et al. [11] critically analyze its SE implications, highlighting operationalization ambiguities; Vaidya [12] transforms governance risk narratives into traceable trust requirements; Kilian et al. [13] document practical standardization challenges under the Act. To our knowledge, none provide an integrated pipeline for validating project-level requirements against specific legal provisions, the gap CARES aims to address.

Large Language Model (LLM)-based & Agentic RE. MARE [14] and Lai et al. [15] demonstrate multi-agent LLM systems achieving human-like RE accuracy. Oriol et al. [16] show iterative agent debate outperforms single-pass approaches. Huang et al. [17] provide a prompt engineering roadmap for RE. Singhal and Breau [4] address legal requirements translation from regulatory text directly. CARES

further leverages Retrieval-Augmented Generation (RAG) [18] to ground LLM reasoning in retrieved legal source documents, reducing hallucination risk in the compliance validation context.

Trustworthy AI Requirements. Villamizar et al. [19] integrate artefact-based and perspective-based RE for Machine Learning (ML) trustworthiness; Donati et al. [20] caution against oversimplifying trustworthiness through checklists; Sadoski et al. [21] address the automation–oversight trade-off in AI decision-making. CARES grounds trustworthiness validation in concrete legal obligations.

III. CARES: VISION & ARCHITECTURE

CARES is a hybrid system combining FM-based agents with HITL oversight that validates project-level requirements against regulatory obligations expressed in natural language. Its core validation logic is governed by the **4CT quality schema** (Section III-C). The architecture, shown in Fig. 1, comprises three parallel initialization tracks feeding into an Agent Orchestrator, which delegates tasks across the Mapping Component, Validation Engine, and HITL mechanism before consolidating results into an auditable report.

A. Parallel Initialization & Agent Orchestrator

On receiving a project document or system description, CARES initiates three parallel tracks: (i) **Agentic RAG**, which retrieves and processes the relevant regulatory text through a Research Agent and Regulatory Obligation Extraction component, decomposing legal provisions into structured, testable obligation items that constitute the *legal compliance baseline*, the law-derived reference set against which project requirements will later be validated; (ii) **Risk Classification**, which determines the applicable EU AI Act risk tier and scope of obligations; and (iii) **Preprocessing**, which parses, chunks, and extracts individual requirements from potentially unstructured project documentation. The outputs of the three initialization tracks (a structured obligation baseline, a risk tier, and parsed project requirements) are handed to the **Agent Orchestrator**, which coordinates the pipeline through a shared memory space (storing intermediate mappings, confidence scores, and escalation flags) and sequential task delegation to the Mapping Component, Validation Engine, and HITL mechanism [15].

B. Mapping Component

The Mapping Component establishes traceable links between legal obligations and project requirements through a **three-tier hierarchy**. **L1 (Compliance Scope)** groups obligations by thematic domain (e.g., *Risk Management*, *Data Governance*, *Technical Documentation*) using rule-based taxonomy assignment maintained independently by legal experts. **L2 (Requirement Cluster)** partitions obligations into article-level groupings via structural parsing and lightweight NLP classification. **L3 (Requirement Item)** maps each project requirement to a specific legal obligation using LLM-based semantic reasoning, producing a *mapping confidence score* and

a *justification trace*. Mappings below the minimum-confidence threshold (e.g., default: 0.50) are flagged for human review rather than accepted automatically [4].

Table I illustrates the hierarchy for EU AI Act Art. 9. REQ-12 (**Green**) satisfies the risk identification obligation through explicit documentation. REQ-07 (**Yellow**) partially addresses residual risk evaluation but lacks explicit acceptance criteria, triggering a re-loop. The absence of any requirement for real-world testing under Art. 9(6) constitutes a Completeness failure (**Red**), escalated to expert review [10], [11].

C. Validation Engine & 4CT Quality Schema

The Validation Engine assesses each project requirement against the **4CT quality schema** (Table II), structured in two tiers. The **four core dimensions** are grounded in IEEE/ISO/IEC 29148:2018 [5]: *Completeness* checks that all legally mandated obligations are covered; *Consistency* checks for contradictions within the specification or with the mapped legal provision; *Correctness* checks that the requirement accurately reflects the legal obligation’s intent; and *Coherence* operationalizes unambiguity and verifiability as a single composite criterion, since unambiguity is a precondition for verifiability, an ambiguous requirement cannot be meaningfully verified against a legal provision [7]. The *promoted Traceability dimension* elevates auditability to a first-class validation concern: unlike its role as an auxiliary process attribute in IEEE 29148:2018, Traceability in CARES constitutes an independent validation dimension (the absence of an auditable, citable link between a project requirement and its originating legal provision is itself a validation failure, regardless of how the requirement scores on the four core dimensions). This promotion is legally mandated: the EU AI Act explicitly requires systematic documentation and auditability of compliance decisions (Art. 11, 12, 17 [2]), making an unauditable assessment legally indefensible [10], [11].

SMART criteria [6], [7] serve a dual role within the 4CT schema: as a *validation sub-criterion* (*Specific* and *Measurable* refine Coherence, *Relevant* refines Correctness, *Testable* refines both Coherence and Traceability) and as a *remediation guide* for Yellow- and Red-flagged requirements (e.g., a Coherence failure caused by a missing *Measurable* criterion triggers the suggestion “Add explicit acceptance thresholds”). *Achievable* and *Time-bound* are omitted, as legal obligations are non-negotiable hard constraints [2]. Both rule-based and LLM-based methods are employed across all dimensions [4].

D. Human-in-the-Loop

CARES treats human oversight as a first-class architectural principle [21]. A **traffic-light classification** is assigned per requirement based on two signals: (i) the 4CT dimension verdict profile, and (ii) the L3 mapping confidence score. A *conservative dominance rule* applies: the most serious dimension failure determines the color, reflecting that a single unresolved compliance gap is sufficient to render a requirement non-compliant. Table III defines the trigger criteria.

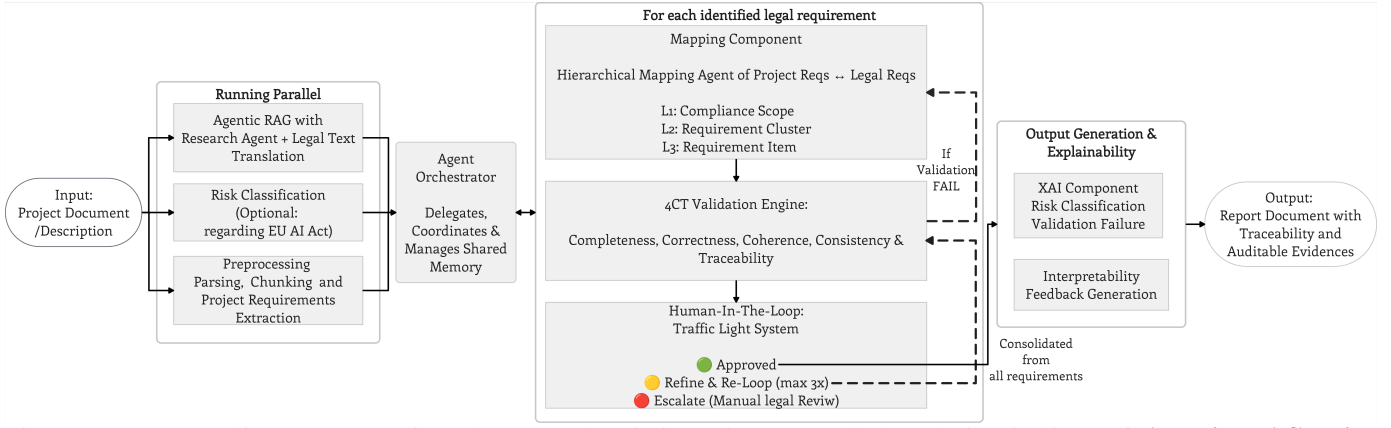


Fig. 1: CARES architecture: A project document/description triggers parallel analysis pipelines of **Agentic RAG**, **Risk Classification**, and **Requirements Preprocessing**, which the **Agent Orchestrator** combines with **Mapping** (L1–L3), **4CT Validation**, and a **HITL traffic-light mechanism** to generate an auditable report.

TABLE I: Illustrative 3-Tier Mapping: EU AI Act Art. 9 against Project Requirements

L1 Scope	L2 Cluster	L3 Legal Req.	L3 Project Req.	L3 Match
Risk Mgmt.	Risk Identification (Art. 9(2)(a))	Provider shall identify and analyze all known and reasonably foreseeable risks.	<i>REQ-12: The provider shall maintain a risk register enumerating all known system risks and their mitigations, updated prior to each release candidate.</i>	Green
Risk Mgmt.	Residual Risk Evaluation (Art. 9(2)(c))	Provider shall evaluate whether residual risks are acceptable after mitigation.	<i>REQ-07: System shall pass all integration tests prior to release.</i>	Yellow
Risk Mgmt.	Real-World Testing (Art. 9(6))	Testing shall be performed on real-world data prior to market placement.	<i>(no matching requirement found)</i>	Red

TABLE II: CARES 4CT Validation Schema

Dim.	Tier	Compliance Check	IEEE 29148	SMART Role
Completeness	Core	All obligations covered	Completeness	Relevant
Consistency	Core	No contradictions	Consistency	—
Correctness	Core	Accurate legal intent	Correctness	Specific
Coherence	Core	Unambiguous & verifiable	Unamb.+Verif.	M + T
Traceability	Prom.	Auditable legal link	Tracea. (elev.)	Testable

SMART Role: attribute used both as validation sub-criterion and as guide for remediation suggestions on Yellow/Red flags. *Achievable* and *Time-bound* omitted (see text).

TABLE III: HITL Traffic-Light Trigger Criteria

	Condition	Action
Green	All 4CT dimensions pass; mapping confidence is high (default: ≥ 0.80)	Accepted; forwarded to report generation.
Yellow	Partial dimension failure or mapping confidence is moderate (default: 0.50–0.79)	Re-loop initiated (max. 3 iterations) alternating Validation Engine and Mapping Component.
Red	Hard dimension failure or mapping confidence is low (default: < 0.50) or Traceability link absent	Immediate expert escalation with a structured Review Package.

Yellow-flagged requirements enter a re-loop capped at three iterations (a provisional bound to be validated in Phase 3,

Section IV). Unresolved cases escalate automatically to Red. As a concrete illustration, a Yellow-flagged REQ-07 surfaces to the reviewer with: the matched legal provision (Art. 9(2)(c)), the 4CT verdict (Coherence: Fail - no measurable acceptance criteria), the LLM justification trace, and a non-binding remediation suggestion (e.g., ‘*Add explicit acceptance thresholds for residual risk evaluation*’). The reviewer may accept, modify, or override the verdict. Confidence boundaries (e.g., default: ≥ 0.80 acceptance, ≥ 0.50 minimum viability) are user-configurable. Phase 3 will first align LLM-generated scores against human expert ratings before calibrating thresholds to balance false negatives (missed gaps, legally critical) against false positives (unnecessary escalations). Each escalated requirement surfaces a *Review Package* comprising the L1/L2/L3 mapping, 4CT verdict profile, LLM justification trace, and re-loop history. The reviewer’s decision is recorded as an immutable audit log entry satisfying Art. 11 and 17 obligations [2], [20].

E. Output & Explainability

CARES consolidates results into a structured **Report Document** providing full traceability and auditable evidence of each compliance decision, with prioritized gap recommendations for development teams. Future versions will support configurable report templates across regulatory frameworks including GDPR [22], MDR [23], and GMP [24].

IV. EVALUATION ROADMAP

Evaluating an automated legal RE tool requires a validated taxonomy, annotated compliance data, and a working prototype, but none of which yet exist. We outline a four-phase roadmap that honestly reflects the current state of CARES as a vision with a planned prototype and structures the path from concept to validated system.

Phase 0: Taxonomy Construction & Prototype. The first step is to operationalize the conceptual architecture presented in this paper. This involves two parallel activities: (i) constructing the L1/L2 mapping taxonomy by systematically decomposing the EU AI Act [2] into Compliance Scopes and Requirement Clusters, carried out collaboratively by the authors and a legal domain expert, and (ii) implementing a minimal PoC prototype covering the Mapping Component and Validation Engine for a scoped subset of obligations (Art. 9–11). The taxonomy and prototype together form the prerequisite for all subsequent phases.

Phase 1: Taxonomy Validation. With the L1/L2 taxonomy drafted, a structured expert inspection will assess its coverage and correctness. A mixed panel (min. 2 legal experts + 2 senior REs) will independently assign a sample of Art. 9–11 obligations to L1/L2 clusters and compare results against the authored taxonomy. The primary metrics are: (i) *coverage completeness*, defined as the proportion of mandatory obligations assignable to at least one L2 cluster without ambiguity; and (ii) *inter-rater agreement*, measured using Cohen’s κ , targeting $\kappa \geq 0.70$ as a threshold for acceptable reliability [9], [25]. Disagreements will be resolved through consensus sessions and used to iteratively refine the taxonomy before Phase 2.

Phase 2: Pilot Annotation Dataset. To evaluate L3 mapping quality and 4CT validation accuracy, we will construct a small, manually annotated pilot dataset (target: 50 requirement pairs covering Art. 9 of the EU AI Act [2]) as a first ground truth reference. Requirements will be sourced from expert-reviewed synthetic system descriptions, reflecting realistic high-risk AI project documentation. Each pair receives four labels: an L2 cluster assignment, the specific legal provision it addresses (or *none*), a binary compliance verdict per 4CT dimension, and a natural-language justification. Annotation quality will be assessed via Fleiss’ κ across three annotators [9], [25]. A successful pilot annotation will inform scope expansion to Art. 9–15 in future work, with the dataset released as an open community resource [4].

Phase 3: End-to-End Pilot Evaluation. Using the Phase 2 dataset as ground truth and the Phase 0 prototype as the system under test, we will evaluate the full CARES pipeline across three dimensions: (i) **Mapping quality** via precision, recall, and F1 for L3 requirement-to-obligation matching; (ii) **Validation accuracy** via per-dimension F1 across the 4CT schema, with false negatives (missed compliance gaps) weighted more heavily than false positives given the legal sensitivity of the task; and (iii) **HITL effectiveness** via intervention rate, re-loop resolution rate, and escalation rate, informing confidence

boundary calibration. A think-aloud user study will assess output interpretability, complemented by LLM-as-judge evaluation [15] as a secondary signal for annotation-expensive dimensions.

A. Open Challenges

Several challenges remain open for the community.

- **Legal ambiguity:** Defining the right automation–human threshold for context-sensitive legal terms (e.g., “adequate”, “appropriate”) requires empirical calibration and legal expert consensus beyond what LLMs alone can provide [11].
- **Taxonomy maintenance:** The L1/L2 mapping taxonomy must evolve as obligations are updated or new regulations emerge, requiring ongoing collaboration between legal experts, REs, and domain specialists.
- **Practitioner acceptance:** Any deployed tool must satisfy four practitioner-identified minimum requirements: end-to-end auditability, guardrails and security by design, constrained HITL autonomy, and robustness to imperfect data [1], [21].
- **HITL scalability:** High escalation rates in large projects risk creating review bottlenecks. Planned mitigations include cluster-based batch review, configurable thresholds, and criticality-ranked escalation queues, to be assessed in Phase 3 (Section IV).
- **Generalizability:** Extending CARES to GDPR [22], MDR [23], and GMP [24] requires validating that the 4CT schema and mapping hierarchy transfer across regulatory structures with differing obligation types.

V. CONCLUSION

We have presented CARES, a vision for a hybrid agent-based system for automated legal compliance and quality requirements validation in RE, motivated by a clear gap in current practice: no systematic tooling exists to validate project-level requirements against legal obligations in a traceable and auditable manner [1], [10], [11]. Its central contribution is a hierarchical three-tier mapping architecture (L1–L3) linking EU AI Act obligations to project requirements, validated by the **4CT quality schema** (four IEEE 29148:2018-grounded core dimensions (Completeness, Consistency, Correctness, and Coherence) and a promoted Traceability dimension [5], [11]) and refined by SMART criteria applied both as validation sub-criteria and as a basis for targeted remediation suggestions [6], [7].

A traffic-light HITL mechanism with formally defined trigger criteria ensures human oversight is a first-class architectural component, not a fallback [21]. A four-phase evaluation roadmap anchors the transition from concept to validated prototype, with an annotated pilot dataset to be released as an open resource.

We invite RE and AI researchers to collaborate on the open challenges identified herein, particularly operationalizing legal ambiguity and validating generalizability across frameworks.

ACKNOWLEDGMENT

We gratefully acknowledge the Department of AI Assurance and Assessments (AAA) and the Lamarr Innovation Group for their collaborative effort, generous funding, and expert guidance, which were indispensable to the successful realization of Project AI Gov for RE.

We acknowledge the use of a generative AI language assistant (Claude, Anthropic) for editing and grammar enhancement purposes in this manuscript. The AI model assisted with refining language and structure only; the intellectual content and ideas presented in this paper remain the sole responsibility of the authors

REFERENCES

- [1] T. Y. E. Lai *et al.*, “From obligation to specification: A survey on validating EU AI Act requirements in RE,” Manuscript in preparation, 2026, available upon request.
- [2] European Parliament and Council of the European Union, “Regulation (EU) 2024/1689 of the european parliament and of the council of 13 june 2024 laying down harmonised rules on artificial intelligence (artificial intelligence act),” <https://eur-lex.europa.eu/eli/reg/2024/1689>, 7 2024, oJ L 2024/1689.
- [3] T. Regnier and P. Poropat, “European artificial intelligence act comes into force,” European Commission Press Corner, 8 2024.
- [4] A. Singhal and T. Breaux, “Legal requirements translation from law,” 2025.
- [5] IEEE/ISO/IEC, “ISO/IEC/IEEE 29148:2018 – systems and software engineering – life cycle processes – requirements engineering,” IEEE, Standard, 2018.
- [6] G. T. Doran, “There’s a S.M.A.R.T. way to write management’s goals and objectives,” *Management Review*, vol. 70, no. 11, pp. 35–36, 1981.
- [7] C. Arora *et al.*, “Automated checking of conformance to requirements templates using natural language processing,” *IEEE Transactions on Software Engineering*, vol. 41, no. 10, pp. 944–968, 2015.
- [8] T. D. Breaux and A. I. Antón, “Analyzing regulatory rules for privacy and security requirements,” *IEEE Transactions on Software Engineering*, vol. 34, no. 1, pp. 5–20, 2008.
- [9] S. Abualhaija *et al.*, “Automated question answering for improved understanding of compliance requirements: A multi-document study,” in *Proc. 30th IEEE International Requirements Engineering Conference (RE’22)*, 2022, pp. 1–12.
- [10] J. Kelly *et al.*, “Navigating the EU AI Act: A methodological approach to compliance for safety-critical products,” IEEE CAI 2024, 2024.
- [11] M. Wagner, M.-T. Wittmann, and M. Borg, “A critical look at the EU AI Act’s requirements and affected systems – who must explain what?” *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)*, pp. 494–503, 2025.
- [12] S. Vaidya, “From risk narratives to trust requirements: Bridging AI governance with requirements engineering,” *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)*, 2025.
- [13] R. Kilian, L. Jäck, and D. Ebel, “European AI standards – technical standardisation and implementation challenges under the EU AI Act,” *European Journal of Risk Regulation*, vol. 16, no. 3, pp. 1038–1062, 2025.
- [14] D. Jin, Z. Jin *et al.*, “MARE: Multi-agents collaboration framework for requirements engineering,” 2024.
- [15] T. Y. E. Lai *et al.*, “Towards multi-agent systems in requirements engineering: A proof-of-concept study using large language models,” Preprint, 2025, accepted at LOD 2025; to appear in LNCS, Springer Nature.
- [16] M. Oriol *et al.*, “Multi-agent debate strategies to enhance requirements engineering with large language models,” 2025.
- [17] K. Huang *et al.*, “Prompt engineering for requirements engineering: A literature review and roadmap,” *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)*, 2025.
- [18] P. Lewis *et al.*, “Retrieval-augmented generation for knowledge-intensive NLP tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [19] H. Villamizar, D. Mendez, and M. Kalinowski, “Towards a framework for operationalizing the specification of trustworthy AI requirements,” *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)*, 2025.
- [20] D. Donati *et al.*, “Beyond the checklist: Rethinking trustworthiness in AI systems,” *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)*, 2025.
- [21] E. Sadovski, I. Aviv, and I. Hadar, “Navigating the human-oversight dilemma in AI-based systems,” *2025 IEEE 33rd International Requirements Engineering Conference Workshops (REW)*, 2025.
- [22] European Parliament and Council of the European Union, “Regulation (EU) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data (general data protection regulation),” <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679>, 2016, oJ L 119, CELEX No. 32016R0679.
- [23] European Parliament and Council of the European Union, “Regulation (EU) 2017/745 of the european parliament and of the council of 5 april 2017 on medical devices (medical device regulation),” <https://eur-lex.europa.eu/legal-content/EN/ALL/?uri=CELEX%3A32017R0745>, 2017, oJ L 117, CELEX No. 32017R0745.
- [24] European Commission, “EudraLex – volume 4: Good manufacturing practice (GMP) guidelines,” https://health.ec.europa.eu/medicinal-products/eudralex/eudralex-volume-4_en, 2024.
- [25] J. James, “Counting on consensus: Selecting the right inter-annotator agreement metric for NLP annotation and evaluation,” 2026.